Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

Purpose

Consider the following questions to help you write:

- *How is the database server valuable to the business?*
- *Why is it important for the business to secure the data on the server?*
- *How might the server impact the business if it were disabled?*

A vulnerability assessment helps the business identify, evaluate, and prioritize security risks in its IT system. The database server is critical because it securely stores customer data and allows quick searches to find potential clients.

Securing this server prevents data breaches that could expose sensitive customer details like names, addresses, and credit card numbers. If the database goes offline, the business would have to rely on slow, disorganized paper records. This would delay daily operations and make it much harder to reach and support customers efficiently.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Obtain sensitive information via exfiltration	Threat source installs malicious software on organizational systems to locate and acquire sensitive information.	*1*	*3*	*3*
Alter/Delete critical information	Threat source alters or deletes data that is critical to day-to-day business operations.	*3*	*3*	*9*
Conduct "man-in-the-middle" attacks	Threat source eavesdrops on sessions between internal and external systems. Later, they relay messages between organizational and external systems that make them believe they're talking directly to each other over a private connection.	*2*	*2*	*4*

Approach

Risks considered the data storage and management methods of the business. The likelihood of a threat occurrence and the impact of these potential events were weighed against the risks to day-to-day operational needs.

Attackers could install malicious software via exfiltration to obtain sensitive information from the database. They could also conduct man in the middle attacks in which the attacker eavesdrops on sessions between servers to gain information. Threat actors could also delete/alter critical information since the database is public to anyone.

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based

access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database.

Using public key infrastructure (PKI) to address the exfiltration of sensitive information. Another approach is that the database should be private and only authorized users can access it using MFA and strong passwords.

The network should be configured using an IPv6 addresses instead of IPv4 to make the server more secure and mitigate man in the middle attacks.